

# **VULNERABILITY ASSESSMENT REPORT**

# 1. Executive Summary

This report presents the findings of a vulnerability assessment performed on a deliberately insecure web application — OWASP Juice Shop.

The objective of this assessment was to identify security weaknesses using passive analysis techniques and widely used security tools.

The assessment was conducted in a **read-only manner** without exploiting vulnerabilities.

# 2. Scope of Assessment

- Target Application: OWASP Juice Shop
- Type: Web Application (Demo / Training Platform)
- Assessment Type: Passive Vulnerability Assessment
- Testing Method: Non-intrusive analysis only

# 3. Tools Used

Browser Developer Tools (Chrome DevTools)

OWASP ZAP (Passive Scan)

Nmap (Basic port scanning)

## 4. Key findings

### 4.1 Exposed Services & Information Disclosure

Observation:

- Server identified as **Heroku**
- Internal routing (heroku-router) exposed
- Hidden endpoint reference (/jobs) visible in headers

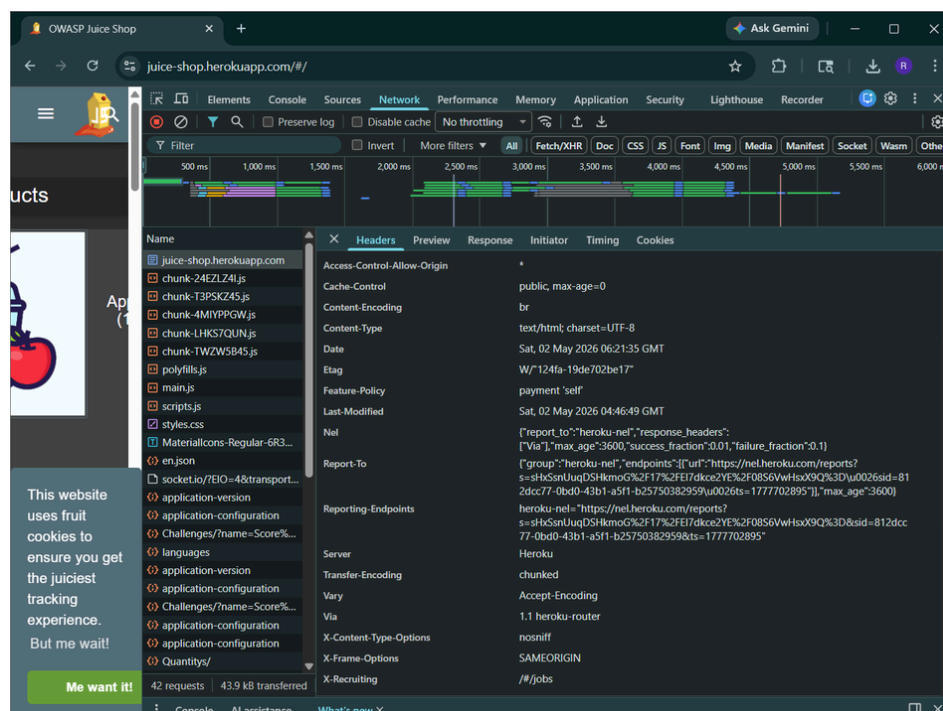
Risk:

Exposure of infrastructure details helps attackers understand the system architecture and plan targeted attacks.

Severity: ● Low

Recommendation:

- Remove unnecessary server headers
- Hide internal endpoint references
- Minimize information disclosure in HTTP headers



## 4.2 Security Header Misconfiguration

### Observation:

- Missing Content-Security-Policy (CSP)
- Missing Strict-Transport-Security (HSTS)
- Open CORS policy (Access-Control-Allow-Origin: \*)
- Basic headers present:
  - X-Frame-Options
  - X-Content-Type-Options

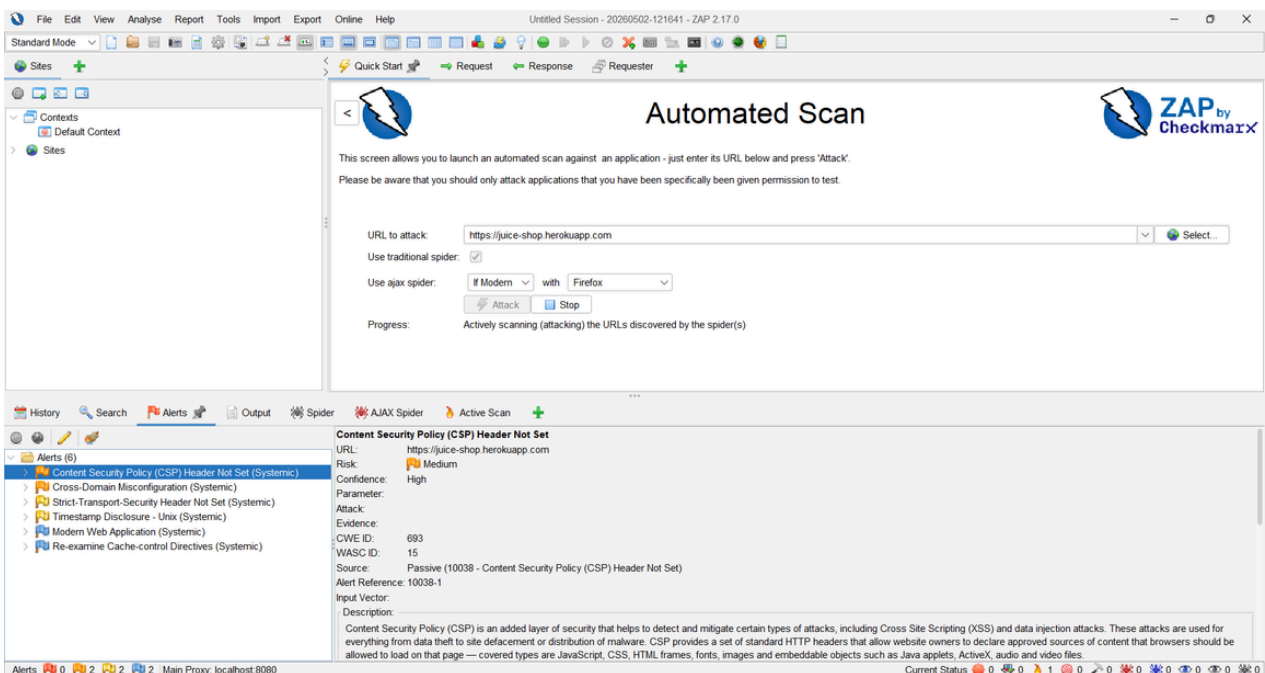
### Risk:

- Increased risk of XSS attacks
- Possible MITM attacks due to missing HSTS
- Cross-origin data exposure

Severity: ● Medium

### Recommendation:

- Implement CSP to restrict script execution
- Enable HSTS for HTTPS enforcement
- Restrict CORS to trusted domains only



## 4.3 Network Exposure

Observation:

Open ports detected:

- 21/tcp (FTP)
- 80/tcp (HTTP)
- 443/tcp (HTTPS)

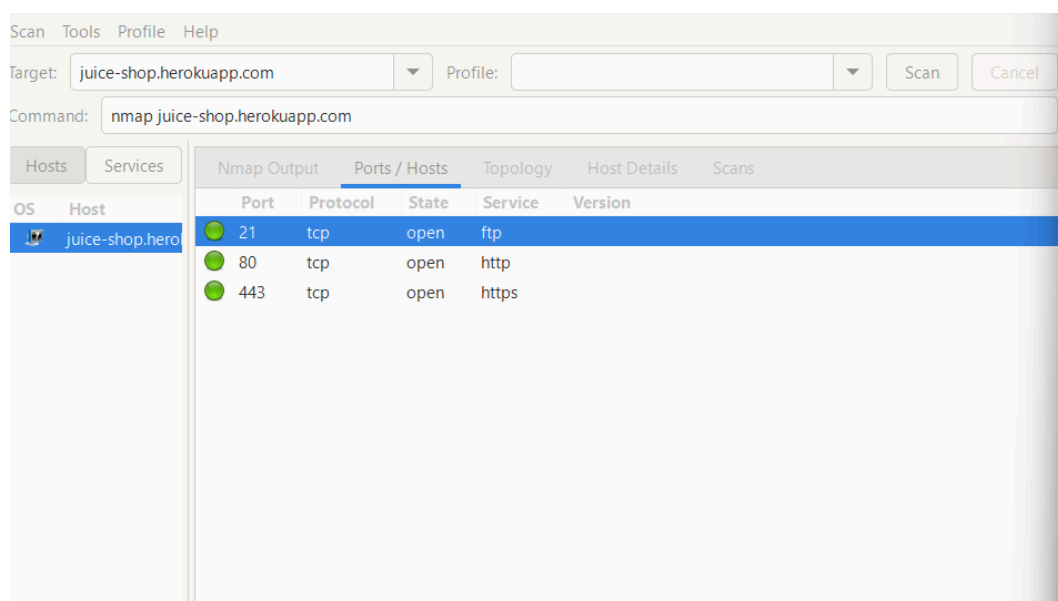
Risk:

- FTP service increases attack surface
- HTTP traffic is unencrypted
- HTTPS is secure but co-exists with insecure services

Severity: ● Medium

Recommendation:

- Disable unused FTP service
- Force HTTP to redirect to HTTPS
- Secure all exposed services



## 4.4 Outdated Components

Observation:

No explicit frontend library versions were exposed in source code. No direct vulnerable component was confirmed during passive analysis.

Risk:

Potential existence of outdated dependencies in backend or bundled scripts.

Severity: ● Low

Recommendation:

- Regular dependency updates
- Use vulnerability scanning tools (Snyk / npm audit)

## 5. Risk Summary

| Category            | Severity |
|---------------------|----------|
| Exposed Services    | Low      |
| Security Headers    | Medium   |
| Network Exposure    | Medium   |
| Outdated Components | Low      |

## 6. Conclusion

The application demonstrates multiple common web security weaknesses including information disclosure, missing security headers, and exposed network services. While no active exploitation was performed, these vulnerabilities increase the potential attack surface.

## 7. Overall Recommendations

- Implement strong security headers (CSP, HSTS)
- Reduce exposed server information
- Secure or disable unnecessary services (FTP)
- Follow secure coding and dependency management practices